

Annex

Proof, not paperwork.

Annex reads your codebase, decides where it falls under the EU AI Act, and proves every obligation with a file, a line and a hash.

Shivam Gupta · github.com/shi1720/LexHack

THE PROBLEM

Every AI Act dossier is a document a company wrote about itself.

Nobody has ever checked one against the system it describes. That is not a snipe at compliance teams — it is structural. The Act asks whether your system logs inference, whether a human can override it, whether you examined your data for bias. **Those answers are in the repository.** The people who write the dossier cannot read it, and the people who can were never asked.

~90

AI GOVERNANCE VENDORS

In the IAPP's 2026 category census.

2

MENTION SOURCE CODE

One is a GDPR privacy scanner. The other is the phrase "a U.S. codebase".

40%

CAN'T BE CLASSIFIED

Of 106 enterprise AI systems studied by appliedAI, the risk tier was unclear.

The deadline moved. The obligations did not.

On 27 July 2026 the Digital Omnibus pushed the Annex III high-risk deadline from August 2026 out to **2 December 2027**, and the compliance industry exhaled. **It left Article 50 exactly where it was.**

In force today

2025-02-02	Article 5 prohibited practices · €35M / 7%
2025-08-02	GPAI model obligations
2026-08-02	Article 50 transparency · €15M / 3%
2023-07-05	NYC Local Law 144 bias audits

What everyone is waiting for

2026-12-02	Art. 50(2) marking, grandfathered systems
2026-12-02	New Art. 5 prohibitions (NCII, CSAM)
2027-12-02	Annex III high-risk — moved from Aug 2026
2028-08-02	Annex I embedded high-risk

If your product talks to a person or generates content, **you have been in scope since August**. The deadline nobody is talking about is the one that already passed.

WHAT IT DOES

One scan. Four artefacts. Under a tenth of a second.

PROHIBITED

Article 5(1)(f) – emotion inference in the workplace

classification Annex III, point 4(a) · recruitment and candidate selection 97% confidence
`src/screening/rank.ts:28`

```
const decision = candidateScore >= ADVANCE_THRESHOLD ? 'advance' : 'reject';
```

- * missing Art. 5(1)(f) **IN FORCE** emotion inference from video interviews
- * missing Art. 50(1) **IN FORCE** the chat UI never says it is an AI
- * missing Art. 14 human oversight – no review step, no override, no stop control
- * missing LL 144 §5-301 no independent bias audit in the last twelve months

conformity  2/100 in force today 1/100
exposure €20,000,000 statutory ceiling (GDPR Art. 83(5)) · EU AI Act €294,000
ledger **4AA4-7D3B-BA5D-D7D7** 14 files · 99 ms

Evidence explorer

Statute on the left, the lines that answer it on the right.

Annex IV dossier

Headings in EN · DE · FR, every unanswerable point left open.

A pull request

Additive files that close what code can close.

Standards exports

SARIF, CycloneDX attestation, ML-BOM.

Not a paperwork problem. A verification problem.

A frontier model can draft a plausible Annex IV document this afternoon. What it cannot do is tell you whether the document is *true*. Two things follow.

The law gets a test suite

A control is a function, so it can be tested. **75 golden fixtures** — each a minimal repository and the status the control must return — plus a suite checking every control against a written-down Article 113 table.

A regex that gets greedier fails the build instead of quietly mis-reporting somebody's conformity.

The evidence ledger, signed

Every result is hashed into a chain — control, status, rule-pack version, the SHA-256 of each file cited — and the root is **signed with Ed25519**.

A chain alone only catches an edit for a reader who has your source. A signature they can check against your key catches it for the reader who does not.

That is the whole difference between a document and a proof.

THE THING ONLY A CODE-GROUNDED TOOL CAN DO

Substantial modification, caught in the pull request.

Article 3(23): a change affecting compliance with Chapter III Section 2 is a **substantial modification**; Article 43(4) re-opens the conformity assessment.

```
$ annex diff --base fixtures/hireflow-remediated --head fixtures/hireflow
```

SUBSTANTIAL MODIFICATION

```
fixtures/hireflow-remediated → fixtures/hireflow
```

The risk classification moved from high to prohibited. A change in the intended purpose is a substantial modification on the face of Article 3(23), and Article 43(4) then requires the conformity assessment to be re-opened and the technical documentation updated.

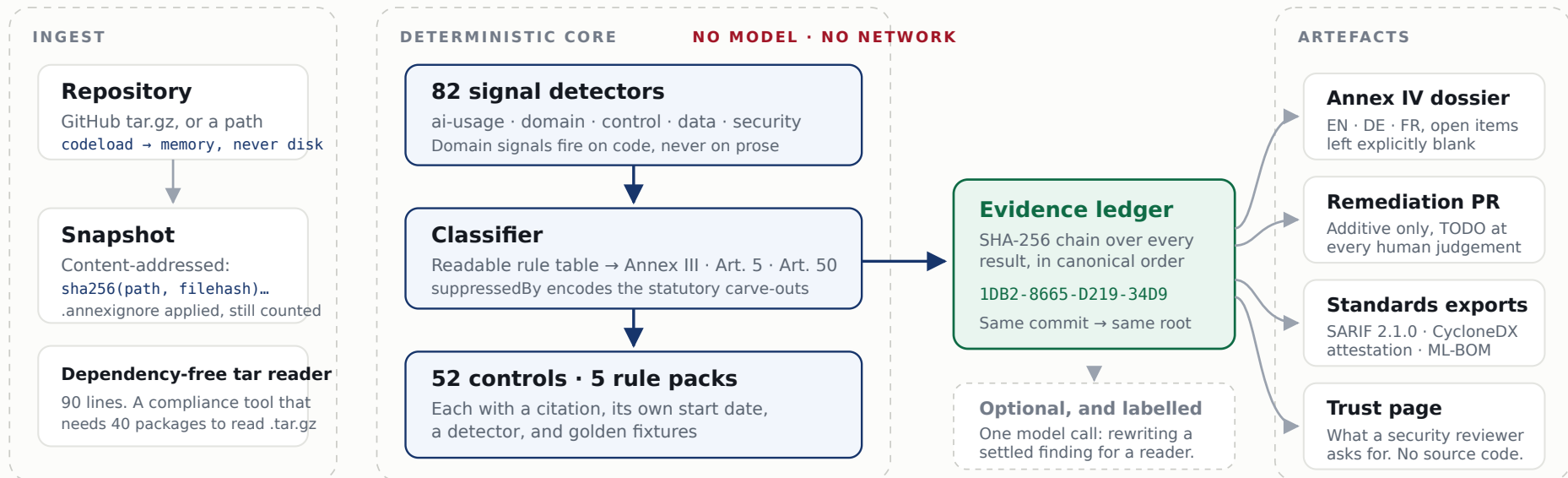
```
conformity 81 → 3 (-78)
tier       high → prohibited
```

```
* No emotion inference in the workplace or education not_applicable → missing
  eu-ai-act.art5.emotion-workplace
... 36 more regressions; pass --all to list them
```

In CI: `--base origin/main --head HEAD`, exit 1. A questionnaire cannot do this — and it is the event that makes the revenue recurring.

HOW IT WORKS

A regulation is a function over a repository.



THE TWO THINGS THAT MAKE IT EVIDENCE

- **The law gets a test suite.** 75 golden fixtures across all five packs, so a detector that drifts fails the build.
- **The ledger is checkable.** annex verify re-derives every entry from the results; --against re-hashes each cited file off disk.

It is a classifier, so it owes you its error rate.

48 hand-labelled cases. Roughly half exist to catch **false positives**: card-fraud detection (excluded from Annex III 5(b)), one-to-one identity verification (excluded from 1(a)), campaign logistics (excluded by 8(b) — nobody sees the output), invoice OCR (Art. 50(2) does not reach re-expression), a mood-journal app that is 1(c) high-risk and *not* the Art. 5(1)(f) prohibition, and a blog post about prohibited practices.

100%

RISK-TIER ACCURACY

100%

FINDING RECALL

100%

CARVE-OUT PRECISION

A clean sheet is a claim about the corpus, not the world

These labels were written by the people who wrote the detectors. The report says so, and five cases exist to find the edge: a lending decision expressed only in SQL, and a chatbot whose AI-ness may or may not be “obvious to a reasonably well-informed person”.

Building it found four real bugs

Domain signals firing on prose; a missing Art. 50(2) rule; broken go.mod parsing; an Art. 50(2) carve-out stated in the caveat and never implemented. Then the self-scan found a GDPR Article 17 gap *in us* — which we fixed.

Three people, one artefact each.

Who	What they feel	What Annex gives them
Engineering lead	"Legal keeps asking me questions about our own code."	A CI check and a pull request. Zero procurement.
Founder / CTO	"An enterprise deal is blocked on an AI governance questionnaire."	A trust page to send back today.
Legal / compliance	"I am signing a document I cannot verify."	Evidence with a citation and a hash.

Pricing follows the statute's unit of account

Free — CLI, GitHub Action, SARIF, classification.

\$35/contributor/mo — blocking PR check, remediation, drift.

\$12–25k per governed AI system/yr — dossier, attestation, freshness.

\$75–250k — enterprise, self-hosted, custom detectors.

The anchors it prices against

€9,900 boutique readiness sprint · \$15–50k consultancy · €75k+ Big-4 programme · €10–40k third-party conformity assessment per system · €193–330k to stand up a QMS, plus €71k/year (EC impact assessment).

The mapping is a commodity. Four other things are not.

Defensible

- **False-positive economics.** Telling a real Art. 14 control from an if approved : branch, across every framework. Endor Labs raised \$93M on exactly this problem in security.
- **Acceptance history.** Which code patterns an assessor actually accepts can only be learned from dossiers accepted and rejected.
- **Workflow position.** A required check on the default branch, plus code Annex wrote that now lives in the customer's repo.
- **Drift detection.** Triggered by a code change; only we see code changes.

What would make me wrong

- The Commission must publish a **free simplified Annex IV form** for SMEs. That is why we sell verification, not generation.
- Code presence is not conformity, and assessors know it. If they treat it as supporting material, the price ceiling drops.
- The category is **\$492M in 2026** (Gartner). This is a wedge into GRC and AppSec, not a standalone category play.
- Budgets follow deadlines. Expect an air pocket until H2 2027.

BUILT FOR THIS HACKATHON

52 obligations. 5 instruments. 0 model calls in the core.

52

EXECUTABLE OBLIGATIONS

82

SIGNAL DETECTORS

135

TESTS, INCL. GOLDEN FIXTURES

450_{ms}

TO SCAN ITS OWN 191 FILES

Rule packs, each reconciled against primary sources

EU AI Act	31 obligations · post-Omnibus dates
GDPR	5 · Arts. 9, 13–17, 22, 35
NYC Local Law 144	5 · the arithmetic is in the rule
Colorado ADMT Act	5 · SB 26-189, from Jan 2027
NIST AI RMF 1.0	6 · version-pinned subcategories

Where the language model is — and is not

The engine never calls one. Classification and control evaluation are rule-based and offline, because an auditor cannot accept "*the model thought so*" as evidence.

There is exactly one model call, labelled `model-written` in the UI: rewriting an **already settled** finding for an engineer, a founder or an assessor. It receives the decision as fact and cannot change it.

A GitHub App, and a dossier in front of a notified body.

The CLI and SARIF output already work in CI. The App turns a scan anyone can ignore into a gate nobody can. After that, the question that decides whether this is a product or a demo is whether an assessor — TÜViT, Nemko, Bureau Veritas — will accept code-grounded evidence as a starting artefact. That is a question about institutions, not code, and it is answered by knocking on doors.

Proof, not paperwork.

Shivam Gupta · LexHack 2026 · github.com/shi1720/LexHack